SECURE-RAG: Auditing Retrieval and Lightweight Adaptation for Cybersecurity Claim Verification

Tulsi Sanskrati Tomar
S24CSEU0084
School of Computer Science Engineering and Technology
Bennett University, Greater Noida, India

Abstract Cybersecurity claim verification requires correct interpretation of supplied evidence and appropriate handling of missing context. This paper evaluates Qwen2.5 3B using three separate studies: a 2,367-example six-task SECURE test, 160 additional structured claims from 40 CVEs, and a matched MLX low-rank adaptation trial. Evidence-first prompting improves test KCV accuracy from 46.10% to 63.12%, but reduces performance on other task families. On additional claims, a cited-retrieval candidate achieves 68.125% accuracy against 91.25% for the full-record original arm. Forty-seven of 142 answers with matching literal citations are incorrect. A fixed 100-step adapter trained from 262 development examples improves KCV validation accuracy from 34/53 to 42/53, or 64.15% to 79.25%, relative to the same quantized MLX base. The paired source-cluster interval for the gain is [+3.57, +27.27] percentage points. The adapter returns the expected X label on 52/53 VOOD examples. These findings support a measured validation improvement and documented retrieval failure; transfer to previously unobserved CVEs remains unmeasured.

Keywords Cybersecurity · SECURE · Claim verification · LoRA · Local language models

1 Introduction

A cybersecurity assistant must distinguish a supported statement, a contradiction and an evidence gap. A correct vulnerability identifier alone does not resolve an incorrect version interval or a reversed user-interaction condition. This project studies these decisions using a small local language model and the SECURE benchmark [1]. Its central question is whether more explicit reasoning, cited retrieval or lightweight adaptation improves the actual decision under a declared evidence boundary.

The project began with retrieval and selective evidence review. Subsequent experiments expanded evaluation to all six SECURE tasks, tested a fixed retrieval candidate on additional CVEs, and trained a small adapter. These stages produce different kinds of evidence and must remain separate. The best development-pilot score cannot be substituted for test accuracy. Similarly, changing the inference runtime requires a matched baseline before attributing a gain to training.

This paper makes a bounded empirical contribution: a reproducible local evaluation with task-specific scoring, a documented failure of a cited retrieval candidate on structured CVE claims, and a matched validation comparison of a fixed low-rank adapter. The contribution is an engineering evaluation and failure analysis. LoRA, retrieval and structured generation are established techniques; this work does not claim to invent them or to surpass the original SECURE study.

The results motivate three research questions. RQ1 asks whether evidence-oriented prompting improves all task families. RQ2 asks whether a literal citation is sufficient evidence of a correct verdict. RQ3 asks whether a small supervised adapter improves claim decisions over the same quantized base model. The following sections describe related work, experimental design, implementation, measured results and limitations.

2 Background and Related Work

2.1 SECURE and the original study

Bhusal et al. introduce SECURE for cybersecurity advisory evaluation [1]. The benchmark covers Malware and Attack Extraction (MAET), Common Weakness Enumeration Extraction (CWET), Knowledge of Common Vulnerabilities (KCV), Vulnerabilities Out of Distribution (VOOD), Risk Evaluation and Reasoning (RERT), and CVSS Problem Solving (CPST). It examines multiple models and customized approaches. Its retrieve-read discussion identifies irrelevant retrieval and missing decisive information as possible failure mechanisms.

Our evaluation uses the official data at revision `a2412e8`. It adds Qwen2.5 3B experiments under a local execution protocol. Historical model scores are contextual references, not controlled comparators: model size, prompts, quantization, evaluation subsets and scoring can differ. The original study's customization experiments also mean that adding RAG or fine-tuning alone is not a defensible algorithmic novelty claim.

2.2 Retrieval and evidence support

RAG supplies non-parametric evidence to a generator [2]. Its usefulness depends on retrieving the right information and interpreting it correctly. A quote can match a source exactly while the verdict reverses the quote's meaning. We

therefore measure literal citation fidelity separately from verdict accuracy. Neither is a substitute for an independently reviewed entailment annotation.

2.3 Low-rank adaptation and staged systems

LoRA freezes base weights and learns a low-rank update [3]. For a weight matrix, the effective update can be written as $W' = W + sBA$, with rank r much smaller than the matrix dimensions. The present trial uses rank eight in the final four transformer layers. Its objective is feasibility and a matched measurement, not a new adaptation algorithm. HMS-IDS [4] provides a useful example of presenting a staged cybersecurity architecture and distinct evaluation components. Its intrusion-detection tasks and datasets differ from language-model claim verification, so its reported accuracy is not a comparator here.

3 Data and Evaluation Design

3.1 Official benchmark and source grouping

The preparation pipeline checks exact SHA-256 values for all six upstream TSV files. It groups connected source URLs, shared CVE mentions in the relevant tasks, identical prompts and repeated CVSS vectors before assigning development, validation and test partitions. Historical pilot sources remain in development. This reduces direct source reuse across partitions and prevents duplicate variants from appearing as independent evidence.

The archived six-task test contains 2,367 examples: 602 MAET, 572 CWET, 282 KCV, 282 VOOD, 569 RERT and 60 CPST. It compares original prompts, evidence-first structured reasoning and self-review by the same local model. The test results are now observed. Further method selection must not treat that partition as an untouched test. The older 144-example pilot and its 93.75% pooled result are historical development evidence and are not the main result of this paper.

3.2 Additional structured CVE collection

The fresh V3 experiment contains 160 claims from 40 distinct 2025 CVEs, four claims per source. Claims concern explicit CNA CVSS v3.1 base-severity and user-interaction fields. The collection is balanced: 80 true and 80 false claims, with 80 severity and 80 user-interaction claims. Labels are generated from recorded JSON pointers and checked against the archived records. Independent human label review remains pending.

The source audit found no CVE-ID intersection with 3,108 identifiers in the six official TSV files. This is dataset-source separation, not proof that the pretrained model never encountered these vulnerabilities. After its results were inspected, V3 became observed development evidence for subsequent research decisions. Any later adapter evaluation on V3 would be an explicitly disclosed transfer diagnostic.

Table 1: Separate experimental collections. Observed validation is not a new test.

Collection	Rows	Groups	Purpose
Six-task test	2,367	By task	Prompt study
Fresh V3	160	40 CVEs	Fixed retrieval test
LoRA development	262	34	Training pool
LoRA validation	106	14	Matched comparison

3.3 Adapter training and validation

The LoRA trial uses only development KCV and VOOD examples as training targets: 262 examples from 34 connected source groups. This pool comprises 131 examples per task. Validation contains 53 KCV and 53 VOOD examples from 14 different groups. The archived audit reports no group, CVE-ID or exact-prompt overlap between training and validation. Validation requests contain no gold label or assistant completion.

All validation KCV gold labels are binary: 20 T and 33 F. All 53 VOOD labels are X. Constant controls therefore matter. Always F reaches 62.26% KCV validation accuracy and always X reaches 100% VOOD accuracy. The latter exposes the structural limitation of using an all-X task as a general uncertainty benchmark.

4 Methodology and Implementation

4.1 Model-only prompt comparison

The six-task study uses Qwen2.5 3B Instruct through Ollama with Q4_K_M quantization. The original arm retains the benchmark prompt. Evidence-first asks for a concise analysis and answer in a fixed JSON schema. Self-review examines the original problem and the preceding answer, then retains or changes that answer. This is repeated inference by the same model, not an independent verifier. No external retrieval or deterministic answer rule supplies the reported six-task model-only verdicts.

The recorded experiment uses temperature 0.7, a 32,768-token requested context and a 512-token generation allowance. A declared parser scores the output without repairing it after looking at its gold label. Self-review cost includes the preceding evidence-first call.

4.2 Fixed cited-retrieval experiment

The V3 study compares full-record original prompts, top-three retrieval with JSON verdict control, and the same top-three passages with a cited candidate. The candidate asks for evidence, reasoning, confidence and a verdict. All three arms use the same installed model digest and inference settings, including a fixed generation seed. There is no extra verifier stage.

The full-record versus retrieved comparison changes selection, representation and instructions together. It therefore evaluates a complete candidate and cannot isolate one causal retrieval effect. The two top-three arms provide a more focused control for the additional citation/reasoning/confidence bundle, although those features still change together. The

CVSS UI field is interpreted using the FIRST v3.1 specification [5].

4.3 Fixed MLX adapter

The adapter uses `mlx-community/Qwen2.5-3B-Instruct-4bit`, pinned at revision `4f83f8f`. Both validation arms use this same checkpoint, tokenizer, prompts, greedy decoding and 16-token output allowance. Only adapter loading differs. Comparing this result directly with the Ollama baseline would confound training with runtime and quantization changes.

Training uses MLX and MLX-LM 0.32.2 on an Apple M3 Pro with 18 GiB unified memory. The fixed configuration uses rank eight, scale 16, zero dropout, batch size one, learning rate 10^{-5}, gradient checkpointing and a 4,096-token maximum training sequence. Prompt tokens are masked from the loss. Training completions contain only T, F or X. No reasoning trace, external corpus or new generated label is added.

The prespecified run performs 100 batch-one updates with seed 20261101. This is sampling updates from a 262-example pool, not a completed epoch over every example. The final step-100 checkpoint is retained. The adapter has 1,662,976 trainable parameters, approximately 0.054% of the reported 3.086-billion-parameter model. A strict parser accepts only a normally completed single-letter response. Both validation arms return valid decisions on all examples.

4.4 Metrics and uncertainty

Classification accuracy is exact-label agreement over every example, with invalid predictions counted as errors. Binary coverage is the fraction answered T or F. For RERT, we report the recorded ROUGE-L F1 implementation: lowercased ASCII alphanumeric tokens, no stemming, and longest-common-subsequence F-score. It measures overlap with a reference, not factual correctness. For CPST, penalized mean absolute deviation gives an invalid response the maximum error of ten. Lower is better.

For a paired comparison, each example contributes $d_i = I(\hat{y}_i^{new} = y_i) - I(\hat{y}_i^{base} = y_i)$. The observed change is $\Delta = N^{-1}\sum_i d_i$. Confidence intervals resample source groups rather than individual correlated claims. The archive uses 2,000 bootstrap draws and seed 20261031. These intervals reflect collection-level source variation under one recorded run. They omit training-seed and model-family uncertainty and are unadjusted for multiple comparisons. We do not pool accuracy, ROUGE-L and CVSS error into one score.

5 Results and Analysis

5.1 Six-task prompting results

Table 2 shows that no prompt is uniformly best. Evidence-first raises KCV accuracy from 46.10% to 63.12%, while self-review retains that KCV score and raises VOOD accuracy to 79.79%. MAET declines under both modifications. The RERT overlap score falls, and CPST error increases substantially. Evidence-first has 52 invalid CPST answers out of 60, which explains much of its penalized error. Parser compliance is part of the evaluated system rather than a reason to exclude difficult outputs.

5.2 The cited candidate fails the fresh test

The original full-record arm answers 146/160 correctly (91.25%). Retrieval with verdict-format control reaches 78/160 (48.75%). The cited candidate recovers to 109/160 (68.125%), but remains 23.125 percentage points below the original arm. Its paired 95% CVE-cluster interval is $[-28.125, -18.125]$ points. It fixes four original errors while breaking 41 previously correct decisions. One cited response exhausts its output budget and receives no valid verdict under the frozen scoring rule.

The result also varies by claim family. The cited arm answers 74/80 severity claims correctly, compared with 73/80 for the original. On user-interaction claims, it falls to 35/80 versus 73/80. It predicts F for all 40 true user-interaction claims. This class-specific failure would be obscured by a single headline score.

Of 159 complete binary cited answers, 142 contain a literal quotation matching a named supplied passage. Forty-seven of those 142 decisions are wrong (33.10%). Among 140 complete responses stating confidence 100, 42 are wrong (30%). Literal text matching and stated confidence therefore cannot be interpreted as correctness guarantees in this run.

For CVE-2025-41244, an archived response quotes a user-interaction field whose value is NONE, then rejects the claim that user interaction is not required. The evidence is present, but its meaning is reversed. This example illustrates semantic interpretation failure. It is an inspection of a saved response, not a completed independent human annotation. The exact source-field line is present in top-three passages for 142/160 claims. This post hoc diagnostic does not prove a causal attribution to retrieval: equivalent vector-string evidence can exist even when the explicit field line is absent.

5.3 Matched adapter validation improves KCV

The matched MLX base answers 34/53 KCV examples correctly (64.15%). The adapter answers 42/53 (79.25%), a gain of 15.09 percentage points. Eleven errors are fixed and three formerly correct answers become wrong. The paired source-cluster interval is [+3.57, +27.27] points. This is a positive result on observed validation from 14 groups, with one training seed.

True-claim recall rises from 4/20 to 13/20, while false-claim recall changes from 30/33 to 29/33. Macro-F1 over the present T/F classes rises from 0.5464 to 0.7814. The adapter reduces a strong F preference, primarily recovering true claims. The remaining 11 KCV errors comprise seven true claims rejected as F, three false claims accepted as T, and one false claim answered X. The three regressions are kcv-0005, kcv-0316 and kcv-0352.

VOOD changes from 53 unsupported F answers to 52 X answers and one unsupported T. This demonstrates changed behavior under these prompts. It does not establish calibrated uncertainty on arbitrary cybersecurity questions, be-

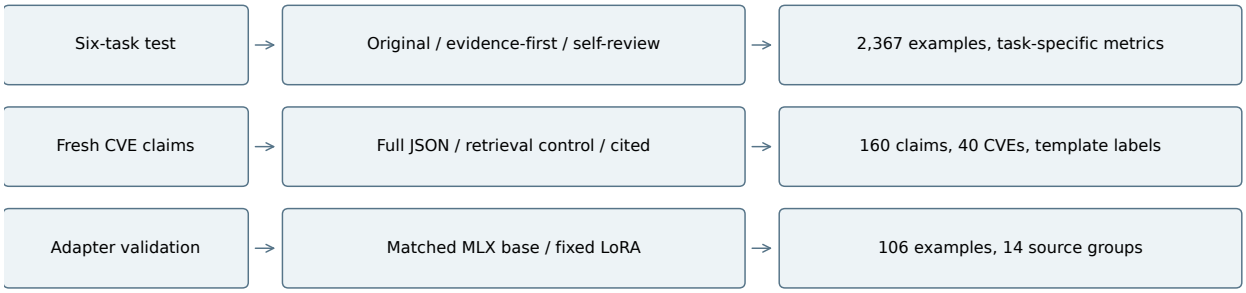


Figure 1: Study design. The three comparisons use different collections and inference configurations. No cross-runtime score is interpreted as the isolated effect of adapter training.

Table 2: Recorded six-task test results. Classification values are percentages. ROUGE-L and CPST retain their own scales.

Task	Metric	N	Original	Evidence-first	Self-review
MAET	Accuracy (%)	602	74.92	74.09	72.26
CWET	Accuracy (%)	572	72.20	72.90	72.73
KCV	Accuracy (%)	282	46.10	63.12	63.12
VOOD	Accuracy (%)	282	54.26	70.21	79.79
RERT	ROUGE-L F1	569	0.4323	0.1614	0.2549
CPST	Penalized MAD, lower better	60	1.9400	8.8708	3.4908

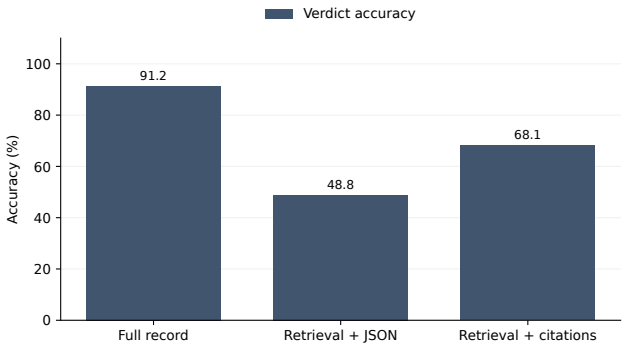


Figure 2: V3 accuracy on 160 template-generated claims. All arms share the same 40 CVE sources. The cited bundle helps its retrieval control, but loses to the full-record original arm.

cause a constant X policy is perfect on this task. No pooled KCV/VOOD headline is used.

5.4 Compute and reproducibility

Recorded training takes 501.23 seconds (8.35 minutes), including validation-loss passes and excluding installation/model download. Inference over 106 validation examples takes 96.05 seconds for the base and 97.72 seconds for the adapter. Fixed stage order, caching and background load prevent treating this as a portable latency ratio. Maximum reported MLX inference peak allocations are 2.716 GB and 2.959 GB. These are not training memory or total system memory measurements. The final adapter occupies 6,657,883 bytes, approximately 6.35 MiB.

The V3 cited arm takes 1,324.53 seconds of measured call time versus 228.58 seconds for its original arm, a 5.79-fold

Table 3: Matched MLX validation. Each task has 53 examples. Controls are fixed constant predictions.

Task	Base	Adapter	Control
KCV correct	34	42	33 (F)
KCV accuracy (%)	64.15	79.25	62.26
VOOD correct	0	52	53 (X)
VOOD accuracy (%)	0.00	98.11	100.00

observed increase. That increase buys lower overall accuracy in this run. Added reasoning or citations therefore require measurement of both benefit and cost.

The supplied archives preserve requests, responses, model/configuration identifiers and hashes. The LoRA audit checks 212 expected arm/example records, effective adapter settings, source separation, parsing and the step-100 adapter fingerprint. Tensor inspection identifies 56 finite F32 tensors in layers 32–35, with nonzero B matrices. Such checks establish archive consistency. They do not independently attest native execution, prove the absence of pretraining contamination or constitute a new inference reproduction on another machine.

6 Discussion and Threats to Validity

The evidence supports a targeted conclusion: a fixed supervised adapter improves matched KCV validation, while cited retrieval can still fail on a simple source-grounded claim task. The experiments expose several distinctions that matter in practice. Finding a field differs from interpreting it. Producing an allowed letter differs from choosing the correct letter. Abstaining on an all-X task differs from calibrated selective prediction.

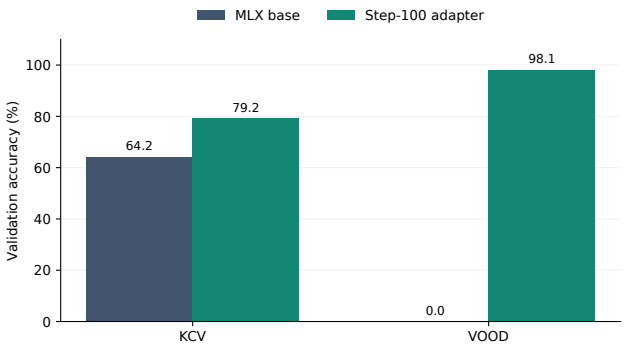


Figure 3: Separate KCV and VOOD validation results. The adapter is compared only with its matched MLX base. All-X VOOD labels limit the interpretation of the abstention score.

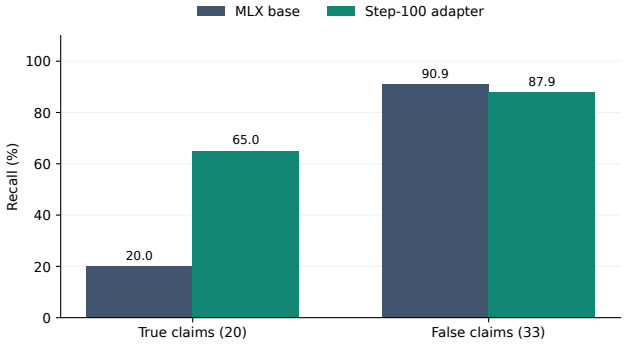


Figure 4: KCV class recall on validation. The main gain is recovery of supported claims; a small loss remains on contradicted claims.

The findings are limited by small adaptation validation, a single seed and one model family. The fresh collection uses templates and machine-derived labels, not diverse analyst-authored questions. Its human review remains incomplete. Source groups account for some dependence, but bootstrap intervals cannot remove dataset construction bias. Different runtimes and quantization prevent direct causal comparisons between Ollama and MLX scores.

The six-task test has already been observed and informed later decisions. The LoRA validation has likewise been inspected. Neither can establish a new untouched generalization result for further tuning. The remaining prerequisite for a stronger claim is to freeze the step-100 adapter and evaluate a matched base on independently prepared, previously unobserved CVEs. That collection should mix supported, contradicted and insufficient-evidence cases with explicit evidence boundaries, while retaining raw responses. Repeated seeds and checks on the other four tasks are also needed before claiming broad improvement.

7 Conclusion

SECURE-RAG provides a local empirical study of evidence handling and lightweight adaptation for cybersecurity claim verification. On the recorded six-task test, explicit reasoning improves some classification tasks while harming risk-overlap and CVSS-scoring performance. On 160 additional structured claims, the cited candidate achieves 68.125% accuracy against 91.25% for the full-record original arm. Literal citations can accompany incorrect decisions.

A fixed 100-step LoRA adapter raises matched KCV validation accuracy from 64.15% to 79.25%, mainly by recovering true claims. This measured optimization is confined to observed validation. The present submission makes no claim of a new adaptation algorithm, superiority over the original SECURE authors, or proven transfer to unseen CVEs. Its practical contribution is the measured comparison, retained negative evidence and auditable separation of training, prompting and evaluation effects.

References

[1] D. Bhusal et al., “SECURE: Benchmarking Large Language Models for Cybersecurity,” in *Annual Computer Security Applications Conference (ACSAC)*, 2024. doi: 10.1109/ACSAC63791.2024.00019.

[2] P. Lewis et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems*, vol. 33, pp. 9459–9474, 2020.

[3] E. J. Hu et al., “LoRA: Low-Rank Adaptation of Large Language Models,” *International Conference on Learning Representations*, 2022. arXiv:2106.09685.

[4] K. Saurabh et al., “HMS-IDS: Threat Intelligence Integration for Zero-Day Exploits and Advanced Persistent Threats in IIoT,” *Arabian Journal for Science and Engineering*, vol. 50, pp. 1307–1327, 2025. doi: 10.1007/s13369-024-08935-5.

[5] FIRST, “Common Vulnerability Scoring System v3.1: Specification Document,” sec. 2.1.4. `https://www.first.org/cvss/v3-1/specification-document`.

[6] T. S. Tomar, “SECURE-RAG implementation and archived experiment records,” project software and accompanying submission artifacts, 2026. `https://github.com/iTulsi/SECURE-RAG`.